

Interview Coach App

OVERVIEW	STACK	DATA	FLows	SECURITY
----------	-------	------	-------	----------

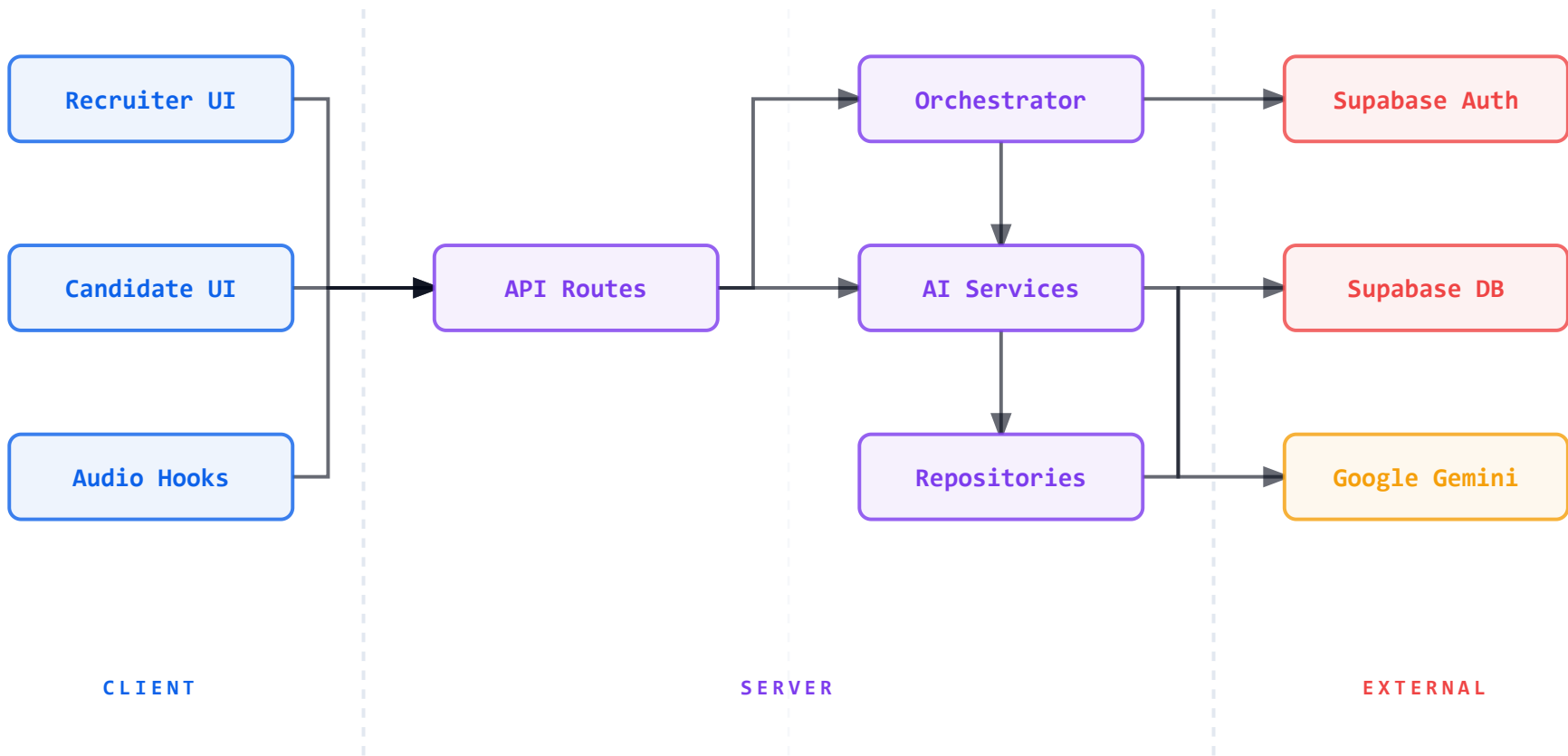
▼ §1 SYSTEM SNAPSHOT

Full-stack **Next.js 14** application supporting recruiter-authenticated workflows and candidate token-based interview practice. AI-driven analysis, response generation, tips, and TTS powered by **Google Gemini**. Persistent state in **Supabase Postgres**.

RECRUITER AUTH Invite creation + review	CANDIDATE FLOW Token-based, no login	AI ANALYSIS Gemini 2.5 Flash	TTS PLAYBACK Audio prefetch cache
--	---	---------------------------------	--------------------------------------

▼ §5 RUNTIME ARCHITECTURE

CLIENT → SERVER → EXTERNAL



▼ §5.1 LAYERING CONTRACT

API Routes

Input validation · Auth/token checks · Delegation only

Orchestration

Owns state transitions

Repositories

Database persistence + mapping

AI Services

Prompts · Model calls · Response parsing

Client

Interaction state + progressive UX

TECHNICAL DESIGN HANDOFF

Interview Coach App

OVERVIEW	STACK	DATA	FLows	SECURITY
----------	-------	------	-------	----------

§2 TECHNOLOGY STACK

FRAMEWORK

Next.js 14 React 18 TypeScript

UI & STYLING

Tailwind CSS Radix UI Framer Motion

DATA & PERSISTENCE

Supabase Postgres Supabase Auth

TESTING

Vitest Testing Library ESLint

§2.4 AI MODEL ALLOCATION

Answer Analysis	gemini-2.5-flash	live
Strong Response Gen	gemini-2.5-flash	live
Tips Generation	gemini-2.5-flash	live
Text-to-Speech	gemini-2.5-flash-preview-tts	live

▼ §4 ENVIRONMENT VARIABLES

SUPABASE_URL

public

SUPABASE_ANON_KEY

public

SUPABASE_SERVICE_ROLE_KEY

secret

GEMINI_API_KEY

secret

DATABASE_URL

server

ENCRYPTION_SECRET

secret

APP_URL

public

SHOW_DEMO_TOOLS

flag

Interview Coach App

OVERVIEW

STACK

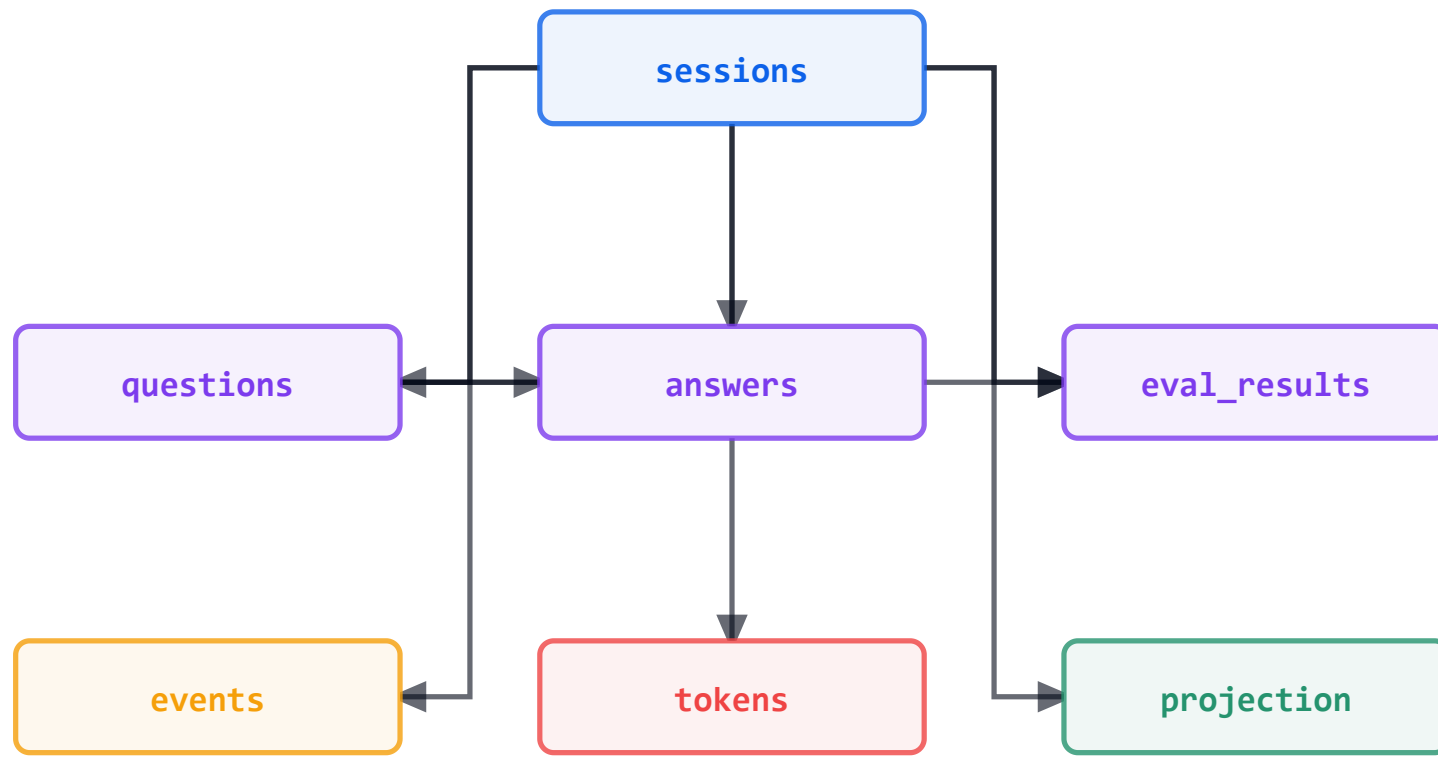
DATA

FLows

SECURITY

▼ §6 DATA MODEL

ENTITY RELATIONSHIPS



sessions

questions

Ordered per session.

answers

Lifecycle root aggregate. Metadata + status + progress.

Keyed by (question_id, attempt_number).

eval_results

AI evaluation payload + metadata.

events

Append-only. Never mutable state.

candidate_tokens

Hashed token-to-session mapping.

projection_session_now

Materialized current session view.

▼ §7 API SURFACE

CANDIDATE-FACING

POST /api/session/start

GET|PATCH /api/session/[id]

PUT /api/.../answer

POST /api/.../submit

POST /api/.../retry

POST /api/.../analysis

POST /api/tts

POST /api/response/generate

RECRUITER / DEV

POST /api/recruiter/invites

GET /api/dev/export-session/[id]

POST /api/dev/generate-questions

POST /api/analysis

SECURITY MODEL

Recruiter → **Supabase Auth** session

Candidate → **x-candidate-token** header

Service role → server-side only

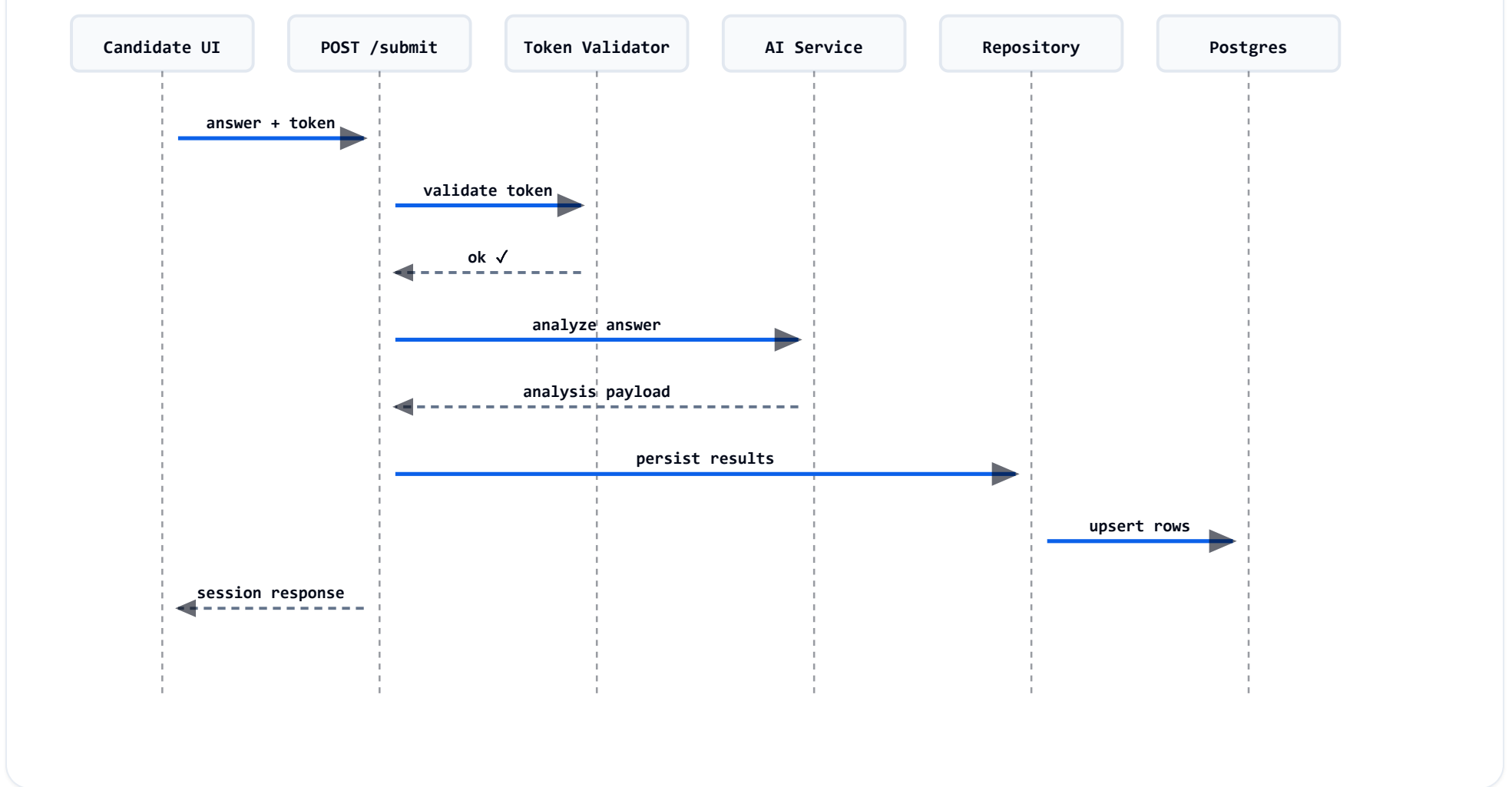
POST /api/tips/generate

Interview Coach App

OVERVIEW	STACK	DATA	FLows	SECURITY
----------	-------	------	-------	----------

▼ §8.2 CANDIDATE SUBMIT → EVALUATION FLOW

SEQUENCE DIAGRAM



▼ §8.3 RETRY FLOW

- 1 Candidate requests retry
- 2 POST /retry + token
- 3 Server validates token

4

Clear prior eval state

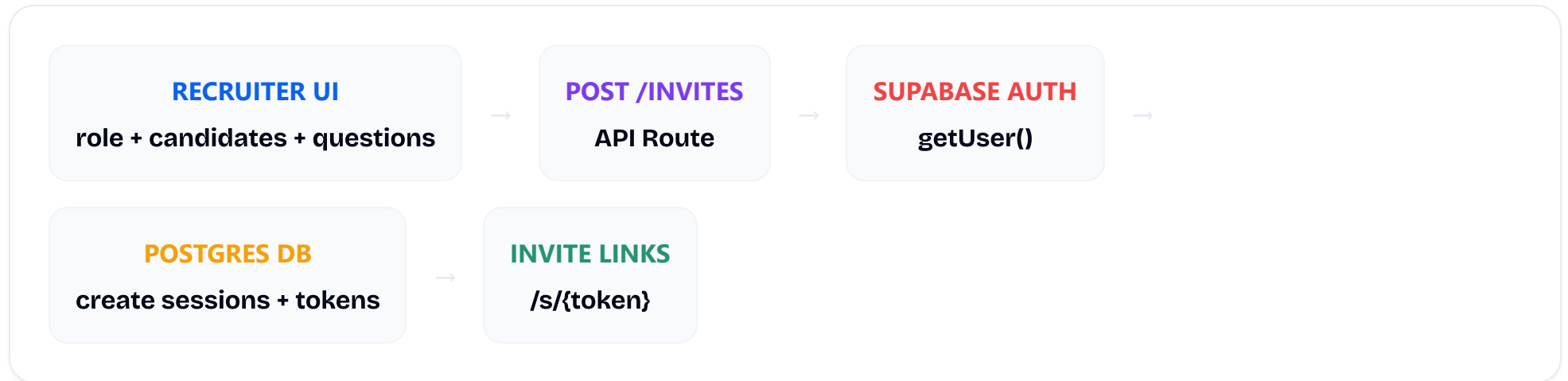
5

Increment attempt state

6

Client reopens input

▼ §8.1 RECRUITER CREATES INVITE



Interview Coach App

OVERVIEW

STACK

DATA

FLOWS

SECURITY

▼ §10 SECURITY & PRIVACY DESIGN

CANDIDATE ACCESS

- Token-gated (hashed server-side)
- x-candidate-token header validation
- No raw token in client storage

RECRUITER ACCESS

- Supabase Auth session
- Middleware cookie refresh
- RLS on all recruiter data paths

SECRET MANAGEMENT

- Service role key → server-only
- Gemini key → server-only
- Encryption secret → server-only

PRIVACY GUARANTEES

- No keystroke logging
- No background surveillance
- No interpretive labels stored

▼ §11 HARDENING OPPORTUNITIES

01 Replace mock QuestionService with Gemini-backed generation + schema validation

high

02 Idempotency protection on submit/retry routes (request-level keys)

high

03 Explicit API versioning strategy (/api/v1/...) before external expansion

medium

04 Observability spans around AI latency, parse failures, DB write timing

medium

▼ §12 DEPLOYMENT RUNBOOK

- 1 Stand up Supabase + configure env vars
- 2 Apply migrations — verify base schema
- 3 npm run dev — smoke tests: npm test
- 4 Verify recruiter auth + invite generation
- 5 Verify candidate token → answer → analysis → retry
- 6 Validate recruiter dashboard session visibility
- 7 Establish dashboards: API errors · AI failures · DB latency